

TP — Le Protocole des Ombres

Sécurisation de la couche d'accès Cisco face à un attaquant à accès physique

« PC_YUGI défend le royaume LAN. PC_MARIK et SWPIRATE tentent d'ouvrir des chemins interdits : prise de pouvoir STP, trunk abusif et traversée du VLAN 20. Chaque défense est posée comme une carte piège Cisco, vérifiée par capture CLI ou ping. »

ÉTUDIANTS	Fehmi Amir · Trid Ilias
MODULE	R4.Cyber.09 — Sécurité des réseaux LAN
ANNÉE	BUT2 Réseaux & Télécommunications · 2025–2026
DATE DE RENDU	Samedi 16 mai 2026 · 23h59
DÉMONSTRATION	Lundi 18 mai 2026 · Salle 409
ENVIRONNEMENT	GNS3 2.2.59 · IOU-L2 · VPCS

Sommaire

Rapport de Travaux Pratiques — Sécurité de la couche d'accès LAN

1.	Introduction & contexte du duel	5
1.1	Problématique générale	5
1.2	Objectifs pédagogiques	5
1.3	Méthodologie & limites assumées	6
2.	Topologie & plan d'adressage	7
2.1	Architecture de l'arène	7
2.2	Plan VLAN et adressage IPv4	8
3.	Baseline réseau — L'Harmonie du Puzzle	9
4.	Sceaux défensifs — Durcissement avant duel	11
4.1	Port-Security sticky	11

4.2	PortFast + BPDU Guard	12
4.3	DHCP Snooping	13
4.4	Dynamic ARP Inspection	14
5.	Attaque STP — L'Usurpation du Pharaon	16
6.	Trunk abusif & VLAN 20 — La Clé du Millénium	18
7.	Scellement final & retour à l'état sûr	20
8.	Synthèse défensive	22
9.	Conclusion	23
A.	Annexes	24
A.1	Outils requis & installation	24
A.2	Manuel d'utilisation de la topologie	25
A.3	Configurations complètes des équipements	26

.....

.....

1 · Introduction & contexte du duel

« Dans les couloirs du Sanctuaire KaibaCorp, Marik n'a pas besoin d'exploit distant : il branche SWPIRATE sur une prise laissée trop permissive. Le duel ne se joue pas sur Internet, mais sur un port d'accès. »

— Yugi Muto, Porteur du Puzzle du Millénium

La sécurité des réseaux locaux ne se résume plus à un pare-feu de périmètre. Dans un réseau d'entreprise, un accès physique à une prise réseau interne peut suffire à contourner une partie des protections périmétriques. C'est précisément ce scénario, banal mais redoutablement efficace, que ce TP entend explorer et neutraliser.

L'arène choisie pour ce duel est une topologie Cisco IOU-L2 montée intégralement sous GNS3 2.2.59. Quatre commutateurs et quatre postes terminaux y simulent un petit réseau d'entreprise, divisé en trois VLANs : un VLAN utilisateur, un VLAN administration sensible et un VLAN natif inutilisé. Face à cette topologie, l'attaquant — incarné par SWPIRATE et PC_EVIL — dispose d'un seul levier : un port physique laissé en configuration permissive. À partir de ce point d'appui, deux vecteurs d'attaque sont successivement étudiés.

Le premier consiste à corrompre l'élection du Root Bridge du protocole Spanning Tree. En annonçant une priorité STP nulle, un attaquant peut détourner l'ensemble de la topologie L2 et s'insérer au centre du réseau. Le second consiste à exploiter un port d'accès basculé en mode trunk pour franchir la frontière entre deux VLANs et atteindre un poste théoriquement isolé. Pour chaque attaque, une défense Cisco standardisée est posée, configurée puis vérifiée par capture CLI ou test ICMP.

1.1 · Problématique générale

La problématique de ce TP peut se formuler ainsi : **un attaquant disposant d'un accès physique à la couche d'accès peut-il détourner le LAN, et comment apporter la preuve formelle qu'il en est définitivement bloqué ?**

Cette formulation repose sur trois hypothèses fortes. Premièrement, on considère l'attaquant capable de brancher un équipement de son choix sur n'importe quelle prise du réseau — hypothèse réaliste dans un open-space, une salle de classe ou un bâtiment partagé. Deuxièmement, on considère que l'attaquant maîtrise les protocoles L2 standards (STP, DTP, DHCP, ARP) et peut donc forger des trames arbitraires. Troisièmement, on exige que chaque défense déployée soit accompagnée d'une *preuve* opérationnelle, et non d'une simple affirmation théorique.

1.2 · Objectifs pédagogiques

Ce travail vise à atteindre quatre objectifs identifiés dans la fiche du module R4.Cyber.09 :

- **Comprendre** les mécanismes d'attaque de niveau 2 — STP spoofing, VLAN hopping par trunk abusif, ARP poisoning, DHCP spoofing — et les protocoles qu'ils exploitent.

- **Configurer** les contre-mesures Cisco correspondantes — Port-Security, PortFast + BPDU Guard, DHCP Snooping, Dynamic ARP Inspection — sur des équipements simulés en mode console.
- **Démontrer** par capture CLI ou test réseau que chaque défense bloque effectivement l'attaque ciblée et qu'aucun chemin de contournement ne subsiste.
- **Articuler** à l'oral le lien entre théorie (mécanisme du protocole vulnérable) et pratique (commande Cisco précise), de façon à pouvoir répondre à une question tirée au sort en salle 409.

1.3 · Méthodologie & limites assumées

Chaque phase du rapport suit un schéma identique en quatre temps : *théorie du mécanisme attaqué, configuration de l'attaque, configuration de la défense, preuve de blocage*. Les captures GNS3 sont datées et numérotées, et les configurations complètes sont annexées pour permettre la reproduction intégrale du TP.

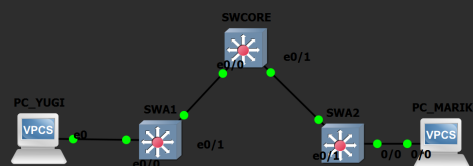
Limite assumée — DTP automatique. Dans nos tests, la négociation automatique du protocole DTP (Dynamic Trunking Protocol) entre une machine attaquante et un port en mode `dynamic auto` n'a pas pu être démontrée de façon reproductible. Le rapport ne prétend donc pas l'avoir prouvée. À la place, l'attaque VLAN 20 est démontrée en plaçant manuellement le port en mode trunk, ce qui produit un état réseau strictement identique à celui qui résulterait d'une négociation DTP réussie — et qui permet donc d'évaluer l'efficacité réelle des contre-mesures.

2 · Topologie & plan d'adressage

2.1 · Architecture de l'arène

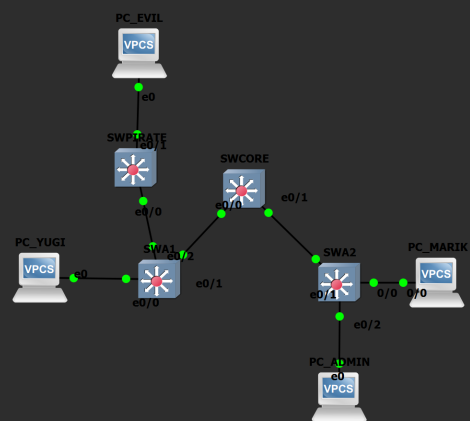
La topologie de test repose sur quatre commutateurs Cisco IOU-L2 et quatre postes VPCS. Un commutateur central — SWCORE — fait office de Root Bridge légitime et héberge les protections les plus sensibles (Dynamic ARP Inspection, DHCP Snooping global). Deux commutateurs d'accès, SWA1 et SWA2, exposent les ports utilisateurs. SWA1 est le commutateur « exposé » : c'est sur son port e0/2 que l'attaquant viendra greffer SWPIRATE et PC_EVIL. SWA2 héberge le poste sensible PC_ADMIN, situé dans le VLAN 20.

Figure 2.1 — Topologie initiale GNS3



État de référence avant insertion de l'attaquant :
PC_YUGI, SWA1, SWCORE, SWA2 et PC_MARIK
opérationnels.

Figure 2.2 — Topologie finale avec
SWPIRATE et PC_ADMIN



SWPIRATE est inséré sur SWA1 e0/2. PC_EVIL accède au
réseau derrière SWPIRATE. PC_ADMIN occupe le VLAN
20 sur SWA2 e0/2.

Équipement	Rôle	Connexions critiques	Adresse / VLAN
PC_YUGI	Poste légitime	SWA1 e0/0	192.168.10.1/24 — VLAN 10
PC_MARIK	Poste utilisateur	SWA2 e0/0	192.168.10.2/24 — VLAN 10
SWCORE	Cœur — Root Bridge légitime, DAI/DHCP Snooping	e0/0 → SWA1, e0/1 → SWA2	Trunks 10,20,99
SWA1	Switch d'accès exposé	e0/0 PC_YUGI · e0/1 trunk SWCORE · e0/2 cible attaque	VLAN 10 + trunks
SWA2	Switch d'accès — archives	e0/0 PC_MARIK · e0/1 trunk SWCORE · e0/2 PC_ADMIN	VLAN 10 + 20
SWPIRATE	Switch pirate (attaquant)	Branché sur SWA1 e0/2	STP priority 0 forcée
PC_EVIL	Hôte attaquant derrière SWPIRATE	SWPIRATE e0/1	192.168.20.66/24 — VLAN 20
PC_ADMIN	Cible sensible	SWA2 e0/2	192.168.20.10/24 — VLAN 20

2.2 · Plan VLAN et adressage IPv4

Trois VLANs sont configurés sur l'ensemble des trunks (10, 20, 99). Le VLAN 99 est volontairement défini comme VLAN natif sur tous les trunks et n'est associé à aucun port d'accès ni à aucun service : il sert exclusivement à neutraliser les attaques par double encapsulation 802.1Q (double tagging), qui exploitent par défaut le VLAN 1.

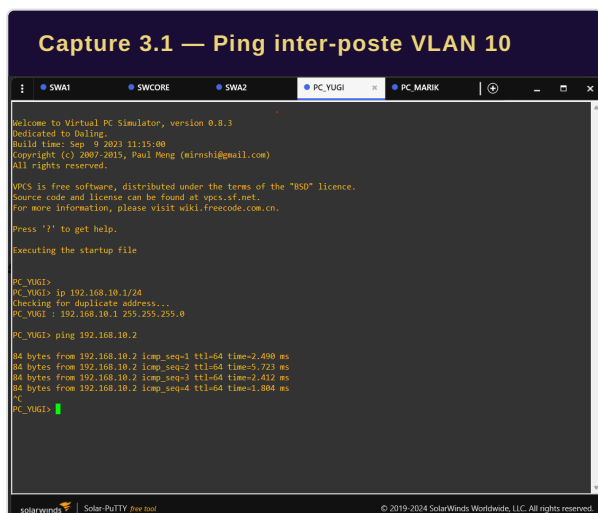
VLAN	Nom	Sous-réseau	Passerelle	Usage
10	VLAN_UTILISATEURS	192.168.10.0/24	192.168.10.254	Postes utilisateurs (PC_YUGI, PC_MARIK)
20	ADMIN/SERVERS	192.168.20.0/24	192.168.20.254	Postes sensibles (PC_ADMIN) — cible de PC_EVIL
99	VLAN_NATIF_INUTILISE	—	—	VLAN natif sur trunks, non routé, sans port d'accès

3 · Baseline réseau — L'Harmonie du Puzzle

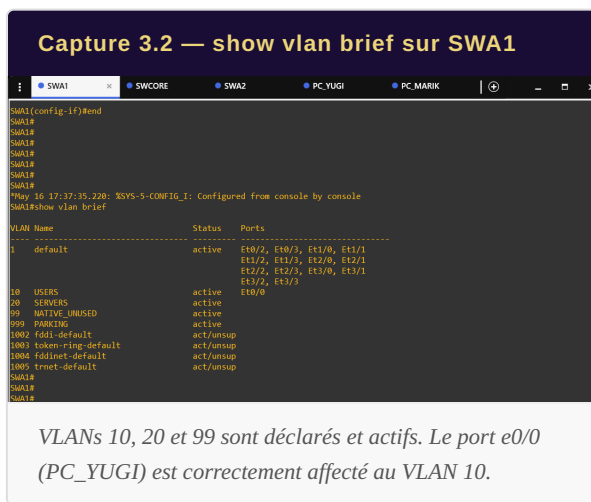
« Avant d'activer les cartes pièges, Yugi prouve que son plateau est stable : VLAN, trunks, STP et connectivité ICMP sont validés. Un duelliste ne convoque pas Exodia si ses cinq fragments ne sont pas réunis. »

— Yugi Muto

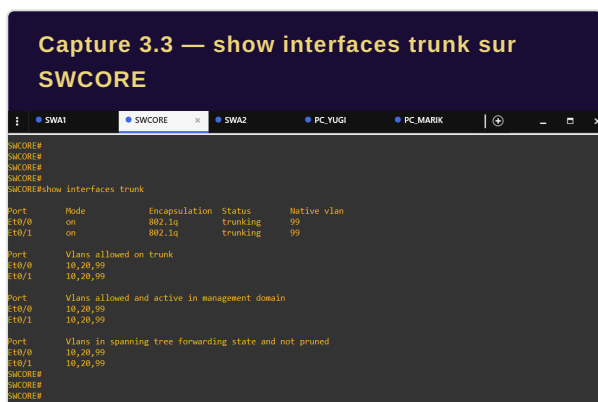
La baseline désigne l'état de référence du réseau avant toute attaque ou tout durcissement. Cet état doit être **déterministe, reproductible et auditable** : sans baseline solide, il devient impossible de distinguer une dégradation provoquée par une attaque d'une simple erreur de configuration. Quatre vérifications systématiques sont effectuées sur la topologie de référence.



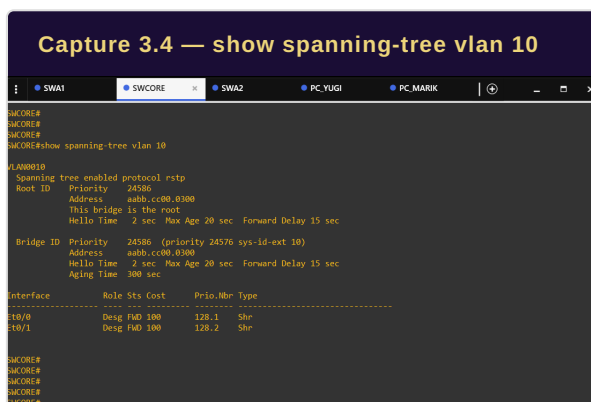
PC_YUGI (192.168.10.1) atteint PC_MARIK (192.168.10.2) — 4 paquets, 0 perdu. La connectivité VLAN 10 est opérationnelle de bout en bout.



VLANs 10, 20 et 99 sont déclarés et actifs. Le port e0/0 (PC_YUGI) est correctement affecté au VLAN 10.



Les deux trunks vers SWA1 et SWA2 portent les VLANs 10, 20 et 99. Le VLAN natif est bien 99 sur les deux liens.



SWCORE est identifié comme Root Bridge légitime du VLAN 10 (priorité 32768, plus basse adresse MAC du domaine).

Validation de la baseline. Les quatre captures ci-dessus constituent la preuve formelle que la topologie est opérationnelle, que l'isolation VLAN est respectée, et que l'élection STP s'est déroulée comme attendu. Toute déviation observée dans les phases suivantes pourra donc être imputée à l'action de l'attaquant, et non à un défaut de configuration initial.

4 · Sceaux défensifs — Durcissement avant duel

« Les cartes pièges sont posées face cachée avant l'attaque. Port-Security limite les MAC, BPDU Guard interdit les BPDU sur port utilisateur, DHCP Snooping sépare ports trusted et untrusted, DAI surveille ARP. Chaque sceau a son rôle, et aucun ne couvre seul l'ensemble du domaine. »

— Seto Kaiba

Avant de simuler la moindre attaque, l'ensemble des protections de la couche d'accès est déployé sur la topologie. Cette approche reflète la pratique réelle de durcissement (*hardening*) telle que recommandée par la documentation Cisco et par les guides ANSSI pour les réseaux d'entreprise. Quatre mécanismes complémentaires sont configurés.

4.1 · Port-Security sticky

Le mécanisme Port-Security limite le nombre d'adresses MAC pouvant être apprises dynamiquement sur un port d'accès. Avec l'option `sticky`, la première adresse MAC observée sur le port est automatiquement gravée dans la *running-config*, ce qui simplifie considérablement le déploiement. Toute trame ultérieure portant une adresse MAC source différente déclenche une violation, et le port passe immédiatement en état `err-disabled` — équivalent fonctionnel d'un débranchement physique.

```
interface Ethernet0/0
description PC_YUGI
switchport mode access
switchport access vlan 10
switchport port-security mac-address sticky
switchport port-security
spanning-tree portfast edge
spanning-tree bpduguard enable
ip dhcp snooping limit rate 10
```

◆ MURMURE DU PUZZLE

Sans l'argument `maximum N`, la valeur par défaut Cisco est de 1 adresse MAC autorisée par port. La directive `violation` n'étant pas spécifiée, l'action par défaut `shutdown` s'applique : le port est désactivé jusqu'à intervention manuelle d'un administrateur.

Capture 4.1 — show port-security interface Ethernet0/0 (SWA1)

```

SWA1#
SWA1#conf t
Enter configuration commands, one per line. End with CNTL/Z.
SWA1(config)#interface ethernet0/0
SWA1(config-if)# switchport port-security
SWA1(config-if)# switchport port-security maximum 1
SWA1(config-if)# switchport port-security mac-address sticky
SWA1(config-if)# switchport port-security violation shutdown
SWA1(config-if)#end
SWA1#
SWA1#show port-security interface ethernet0/0
Port Security           : Enabled
Port Status              : Secure-down
Violation Mode           : Shutdown
Aging Time               : 0 mins
Aging Type               : Absolute
SecureStatic Address Aging : Disabled
Maximum MAC Addresses    : 1
Total MAC Addresses      : 0
Configured MAC Addresses : 0
Sticky MAC Addresses     : 0
Last Source Address:Vlan : 0000.0000.0000:0
Security Violation Count : 0

SWA1#show port-security address
*May 16 17:41:46.297: %SYS-5-CONFIG_I: Configured from console by console
SWA1#show port-security address
      Secure Mac Address Table
-----
Vlan  Mac Address      Type               Ports  Remaining Age
-----
Total Addresses in System (excluding one mac per port)  : 0
Max Addresses limit in System (excluding one mac per port) : 4096
SWA1#

```

Port-Security est activé, 1 MAC sticky enregistrée, mode de violation = shutdown.

4.2 · PortFast + BPDU Guard

Un port d'accès auquel est connecté un terminal final (PC, imprimante, téléphone IP) n'a aucune raison légitime d'émettre des trames BPDU — celles-ci sont l'apanage des commutateurs participant au protocole Spanning Tree. La directive `spanning-tree bpduguard enable`, appliquée à un port marqué `portfast`, désactive immédiatement ce port s'il reçoit une seule BPDU. Couplé à PortFast, qui fait passer le port directement en état *forwarding* sans attendre les phases d'apprentissage, ce mécanisme constitue la défense canonique contre toute insertion de commutateur pirate.

Capture 4.2 — running-config interface Ethernet0/2 (SWA1)

```

SWA1#
SWA1#
SWA1#conf t
Enter configuration commands, one per line. End with CNTL/Z.
SWA1(config)#interface ethernet0/0
SWA1(config-if)# spanning-tree portfast
SWA1(config-if)# spanning-tree bpduguard enable
SWA1(config-if)#end
SWA1#
SWA1#show running-config interface ethernet0/0
Building configuration...

Current configuration : 233 bytes
!
interface Ethernet0/0
  description PC_YUGI
  switchport access vlan 10
  switchport mode access
  switchport port-security mac-address sticky
  switchport port-security
  spanning-tree portfast edge
  spanning-tree bpduguard enable
end
SWA1#
*May 16 17:43:14.847: %SYS-5-CONFIG_I: Configured from console by console
SWA1#
SWA1#
SWA1#
SWA1#
SWA1#
SWA1#

```

Le port utilisateur destiné à recevoir SWPIRATE est préparé : *spanning-tree portfast + bpduguard enable*.

4.3 · DHCP Snooping

DHCP Snooping classe les ports du commutateur en deux catégories : *trusted* (autorisés à transmettre des réponses DHCP) et *untrusted* (toute réponse DHCP y est immédiatement détruite). Seuls les ports menant au serveur DHCP légitime — typiquement les uplinks vers le cœur de réseau — doivent être déclarés *trusted*. Le mécanisme construit en parallèle une *binding table* associant chaque triplet IP/MAC/Port observé via une transaction DHCP légitime ; cette table servira ensuite de base de référence à Dynamic ARP Inspection.

```

ip dhcp snooping
ip dhcp snooping vlan 10,20
no ip dhcp snooping information option
!
interface Ethernet0/1
  ip dhcp snooping trust

```

Capture 4.3 — show ip dhcp snooping (SWA1)

```

SWA1#
SWA1#conf t
Enter configuration commands, one per line. End with CNTL/Z.
SWA1(config)#ip dhcp snooping
SWA1(config)#ip dhcp snooping vlan 10,20
SWA1(config)#no ip dhcp snooping information option
SWA1(config)#
SWA1(config)#interface ethernet0/0
SWA1(config-if)# ip dhcp snooping limit rate 10
SWA1(config-if)#
SWA1(config-if)#interface ethernet0/1
SWA1(config-if)# ip dhcp snooping trust
SWA1(config-if)#end
SWA1#
SWA1#show ip dhcp snooping
Switch DHCP snooping is enabled
Switch DHCP gleaning is disabled
DHCP snooping is configured on following VLANs:
10,20
DHCP snooping is operational on following VLANs:
10,20
DHCP snooping is configured on the following L3 Interfaces:

Insertion of option 82 is disabled
  circuit-id default format: vlan-mod-port
  remote-id: aabb.cc00.0100 (MAC)
Option 82 on untrusted port is not allowed
Verification of hwaddr field is enabled
Verification of giaddr field is enabled
DHCP snooping trust/rate is configured on the following Interfaces:

```

Interface	Trusted	Allow option	Rate limit (pps)
Ethernet0/0	no	no	10
Ethernet0/1	yes	yes	unlimited

```

SWA1#
*May 16 17:45:12.119: %SYS-5-CONFIG_I: Configured from console by console
SWA1#

```

DHCP Snooping est actif sur les VLANs 10 et 20. Le trunk e0/1 est trusted ; les ports utilisateurs restent untrusted par défaut.

4.4 · Dynamic ARP Inspection

DAI intercepte chaque trame ARP reçue sur un port *untrusted* et la confronte à la binding table construite par DHCP Snooping. Si l'IP source ne correspond pas à la MAC enregistrée sur ce port, la trame est immédiatement détruite et une entrée est ajoutée aux journaux système (**SW_DAI-4-...**). DAI sans DHCP Snooping est inopérant : les deux mécanismes forment une paire indissociable.

```

ip arp inspection vlan 10,20
!
interface <TRUNK_LEGITIME>
  ip arp inspection trust
  ip dhcp snooping trust
!
! Ports utilisateurs : untrusted par défaut

```

Capture 4.4 — show ip arp inspection (SWCORE)

SWA1SWCORESWA2PC_YUGIPC_MARIK

```
SWCORE#
SWCORE#conf t
Enter configuration commands, one per line. End with CNTL/Z.
SWCORE(config)#ip arp inspection vlan 10,20
SWCORE(config)#
SWCORE(config)#interface ethernet0/0
SWCORE(config-if)# ip arp inspection trust
SWCORE(config-if)#
SWCORE(config-if)#interface ethernet0/1
SWCORE(config-if)# ip arp inspection trust
SWCORE(config-if)#end
SWCORE#
SWCORE#show ip arp inspection

Source Mac Validation      : Disabled
Destination Mac Validation: Disabled
IP Address Validation      : Disabled

Vlan  Configuration  Operation  ACL Match  Static ACL
----  -
10    Enabled         Active
20    Enabled         Active

Vlan  ACL Logging  DHCP Logging  Probe Logging
----  -
10    Deny        Deny         Off
20    Deny        Deny         Off

Vlan  Forwarded  Dropped  DHCP Drops  ACL Drops
----  -
10    0          0        0           0
20    0          0        0           0

Vlan  DHCP Permits  ACL Permits  Probe Permits  Source MAC Failures
----  -
10    0            0            0              0

SWCORE#show ip arp inspection vlan 10
*May 16 17:47:00.380: NSYS-5-CONFIG I: Configured from console by console
SWCORE#show ip arp inspection vlan 10

Source Mac Validation      : Disabled
Destination Mac Validation: Disabled
IP Address Validation      : Disabled

Vlan  Configuration  Operation  ACL Match  Static ACL
----  -
10    Enabled         Active

Vlan  ACL Logging  DHCP Logging  Probe Logging
----  -
10    Deny        Deny         Off

SWCORE#
```

DAI est actif sur les VLANs 10 et 20. Les deux trunks (e0/0 et e0/1) sont déclarés trusted ; l'inspection ne s'applique donc qu'au trafic entrant par les ports d'accès.

NOTE TECHNIQUE - DAI ET ADRESSES STATIQUES

Dans cette maquette, PC_EVIL et PC_ADMIN utilisent des adresses statiques VPCS. DAI bloque donc les ARP de PC_EVIL lorsqu'aucune entrée DHCP Snooping Binding ne valide son couple IP/MAC/port/VLAN. En production, deux options sont possibles : utiliser DHCP pour alimenter la binding table, ou déclarer des bindings/ARP ACL statiques.

5 • Attaque STP — L'Usurpation du Pharaon

« Marik ne veut pas simplement traverser le réseau : il veut devenir Pharaon du spanning-tree. Il invoque SWPIRATE sur un port utilisateur et annonce une priorité STP de 0 — valeur absolue, irrésistible pour tout commutateur honnête. »

— Seto Kaiba

Le Spanning Tree Protocol (IEEE 802.1D et ses évolutions RSTP/MSTP) élit un commutateur de référence — le Root Bridge — sur la base d'une valeur de priorité administrative (entier sur 16 bits, défaut 32768) à laquelle est concaténée l'adresse MAC du commutateur. Le commutateur présentant le couple le plus bas remporte l'élection. Un attaquant capable de connecter un commutateur de son choix au réseau peut donc, en configurant une priorité égale à 0, se proclamer Root Bridge légitime et faire transiter par lui une partie du trafic, ouvrant la voie à des attaques d'interception ou de déni de service.

1

Port protégé

2

SWPIRATE branché

3

BPDU émise

4

err-disabled

5

Logs preuve

Configuration de la défense — SWA1 e0/2

```
interface Ethernet0/2
description PORT_TEST_SWITCH_PIRATE
switchport mode access
switchport access vlan 10
spanning-tree portfast
spanning-tree bpduguard enable
```

Configuration de l'attaque — SWPIRATE

```
hostname SWPIRATE
spanning-tree vlan 10 priority 0
! Émet immédiatement des BPDU avec priorité 0
! Toute interface réceptrice doit reconnaître la suprématie
```


Capture 5.1 — SWA1 e0/2 préparé

```

SWA1#
SWA1#
SWA1#
SWA1#
SWA1#
SWA1#conf t
Enter configuration commands, one per line. End with CHL/Z.
SWA1(config)#interface ethernet0/2
SWA1(config-if)# description PORT_TEST_SWITCH_PIRATE
SWA1(config-if)# switchport mode access
SWA1(config-if)# switchport access vlan 10
SWA1(config-if)# spanning-tree portfast
Warning: portfast should only be enabled on ports connected to a single
host. Connecting hubs, concentrators, switches, bridges, etc... to this
interface when portfast is enabled, can cause temporary bridging loops.
Use with CAUTION

$Portfast has been configured on Ethernet0/2 but will only
have effect when the interface is in a non-trunking mode.
SWA1(config-if)# spanning-tree bpduguard enable
SWA1(config-if)# no shutdown
SWA1(config-if)#end
SWA1#show running-config interface ethernet0/2
Building configuration...

Current configuration : 178 bytes
!
interface Ethernet0/2
description PORT_TEST_SWITCH_PIRATE
switchport access vlan 10
switchport mode access
spanning-tree portfast edge
spanning-tree bpduguard enable
end
SWA1#
May 16 18:05:34.881: %SYS-5-CONFIG_I: Configured from console by console
May 16 18:05:35.533: %SPANTRIE-2-BLOCK_BPDUGUARD: Received BPDU on port Et0/2 with BPDU Guard enabled. Disabling port.
May 16 18:05:35.533: %PM-4-ERR_DISABLE: bpduguard error detected on Et0/2, putting Et0/2 in err-disable state
SWA1#
May 16 18:05:35.887: %LINEPROTO-5-UPDOWN: Line protocol on Interface Ethernet0/2, changed state to down
SWA1#
May 16 18:05:37.539: %LINK-3-UPDOWN: Interface Ethernet0/2, changed state to down
SWA1#

```

PortFast et BPDU Guard sont actifs avant la connexion de SWPIRATE.

Capture 5.2 — SWPIRATE priority 0

```

SWPIRATE(config)#
SWPIRATE(config)#
SWPIRATE(config)#vlan 10
SWPIRATE(config-vlan)# name USERS
SWPIRATE(config-vlan)#
SWPIRATE(config-vlan)#spanning-tree vlan 10 priority 0
SWPIRATE(config)#
SWPIRATE(config)#interface ethernet0/0
SWPIRATE(config-if)# switchport mode access
SWPIRATE(config-if)# switchport access vlan 10
SWPIRATE(config-if)# no shutdown
SWPIRATE(config-if)#end
SWPIRATE#
May 16 18:06:34.246: %SYS-5-CONFIG_I: Configured from console by console

```

SWPIRATE est configuré pour tenter l'usurpation du Root Bridge.

Capture 5.3 — Port en err-disabled

```

SWA1#
SWA1#show interfaces status

Port      Name      Status      Vlan    Duplex  Speed Type
-----
Et0/0     PC_YUGI   connected   10      auto    auto unknown
Et0/1     TRUNK_TO_SWCORE connected trunk    auto    auto unknown
Et0/2     PORT_TEST_SWITCH_P err-disabled 10      auto    auto unknown
Et0/3     connected 1          auto    auto unknown
Et1/0     connected 1          auto    auto unknown
Et1/1     connected 1          auto    auto unknown
Et1/2     connected 1          auto    auto unknown
Et1/3     connected 1          auto    auto unknown
Et2/0     connected 1          auto    auto unknown
Et2/1     connected 1          auto    auto unknown
Et2/2     connected 1          auto    auto unknown
Et2/3     connected 1          auto    auto unknown
Et3/0     connected 1          auto    auto unknown
Et3/1     connected 1          auto    auto unknown
Et3/2     connected 1          auto    auto unknown
Et3/3     connected 1          auto    auto unknown
SWA1#

```

Dès réception de la première BPDU, SWA1 e0/2 est désactivé : show interfaces status err-disabled.

Capture 5.4 — Journaux BPDU Guard

```

SWA1#
SWA1#
SWA1#show logging | include BPDUGUARD
Syslog logging: enabled (0 messages dropped, 0 messages rate-limited, 0 flushes, 0 overruns, xml disabled, filtering disabled)
May 16 18:05:35.533: %SPANTRIE-2-BLOCK_BPDUGUARD: Received BPDU on port Et0/2 with BPDU Guard enabled. Disabling port.
May 16 18:05:35.533: %PM-4-ERR_DISABLE: bpduguard error detected on Et0/2, putting Et0/2 in err-disable state

```

show logging — l'événement est tracé. La preuve de blocage est conservée pour audit.

Résultat. SWPIRATE n'est jamais devenu Root Bridge. Sa première tentative d'émettre une BPDU sur le port utilisateur a déclenché la mise en err-disabled de l'interface. La topologie STP est restée stable et SWCORE a conservé la couronne tout au long du test.

6 · Trunk abusif & VLAN 20 — La Clé du Millénium

« La Clé du Millénium ne force pas la serrure : elle profite d'une porte déjà entrouverte. Ici, cette porte est SWA1 e0/2 lorsqu'il transporte les VLANs 10, 20 et 99 vers SWPIRATE. »

— Ishizu Ishtar

Le VLAN hopping désigne l'ensemble des techniques permettant à un attaquant placé dans un VLAN d'envoyer ou de recevoir du trafic d'un autre VLAN, en violation de l'isolation L2 prévue. Deux variantes existent : la double encapsulation 802.1Q (neutralisée ici par le choix d'un VLAN natif inutilisé) et le détournement d'un port d'accès en mode trunk. C'est cette seconde variante qui est démontrée ci-dessous.

Démarche prudente. Plutôt que de revendiquer une négociation DTP réussie — que nos tests n'ont pas permis de reproduire de façon stable —, nous reproduisons manuellement l'état réseau qui résulterait d'une telle négociation : SWA1 e0/2 est explicitement basculé en mode trunk. L'impact observé est strictement identique à celui d'une attaque DTP réelle, ce qui permet d'évaluer correctement l'efficacité de la défense.

1

e0/2 trunk

2

VLAN 20 transporté

3

PC_EVIL en VLAN 20

4

Ping PC_ADMIN OK

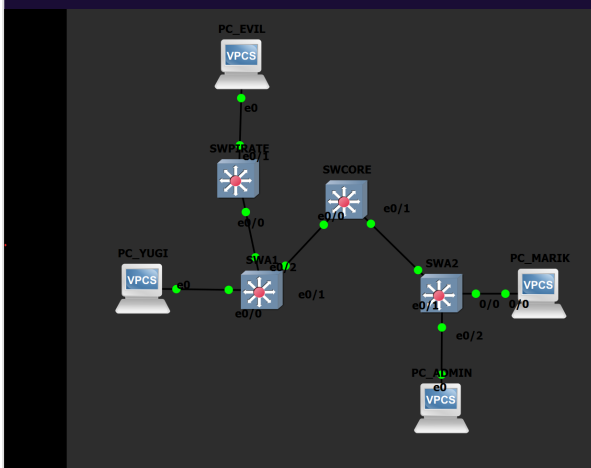
5

DAI bloque

État vulnérable reproduit — SWA1 e0/2

```
interface Ethernet0/2
description PORT_COMPROMIS_TRUNK
switchport trunk encapsulation dot1q
switchport mode trunk
switchport trunk native vlan 99
switchport trunk allowed vlan 10,20,99
```

Capture 6.1 — Topologie d'attaque VLAN 20



Le chemin d'attaque traverse PC_EVIL → SWA1 → SWCORE → SWA2 → PC_ADMIN.

Capture 6.2 — Configuration vulnérable

```
SWA1#
SWA1>conf t
Enter configuration commands, one per line. End with CNTL/Z.
SWA1(config)#interface ethernet0/2
SWA1(config-if)# shutdown
SWA1(config-if)# no spanning-tree bpduguard enable
SWA1(config-if)# switchport trunk encapsulation dot1q
SWA1(config-if)# switchport mode trunk
SWA1(config-if)# switchport trunk native vlan 99
SWA1(config-if)# switchport trunk allowed vlan 10,20,99
SWA1(config-if)# no shutdown
SWA1(config-if)#end
SWA1#
SWA1#show interfaces trunk
Port      Mode      Encapsulation  Status        Native vlan
---      -
Et0/1    on        802.1q         trunking      99
Port      Vlans allowed on trunk
---      -
Et0/1    10,20,99
Port      Vlans allowed and active in management domain
---      -
Et0/1    10,20,99
Port      Vlans in spanning tree forwarding state and not pruned
---      -
Et0/1    10,20,99
SWA1#
May 16 18:41:44.618: %SYS-5-CONF10_1: Configured from console by console
SWA1#
May 16 18:41:46.614: %LINE-3-UPDOWN: Interface Ethernet0/2, changed state to up
May 16 18:41:47.621: %LINEPROTO-5-UPDOWN: Line protocol on Interface Ethernet0/2, changed state to up
SWA1#
```

SWA1 e0/2 est basculé en mode trunk, autorisant explicitement le VLAN 20.

Capture 6.3 — Impact démontré : PC_EVIL atteint PC_ADMIN

```
PC_EVIL> ping 192.168.20.10

84 bytes from 192.168.20.10 icmp_seq=1 ttl=64 time=0.736 ms
84 bytes from 192.168.20.10 icmp_seq=2 ttl=64 time=1.118 ms
84 bytes from 192.168.20.10 icmp_seq=3 ttl=64 time=1.104 ms
84 bytes from 192.168.20.10 icmp_seq=4 ttl=64 time=1.281 ms
^C
PC_EVIL>
PC_EVIL>
PC_EVIL>
PC_EVIL>
PC_EVIL>
```

Avec DAI temporairement relâchée pour démontrer l'impact, PC_EVIL (192.168.20.66) ping PC_ADMIN (192.168.20.10) avec succès. Le chemin VLAN 20 est exploitable lorsque les protections sont absentes.

Conséquence concrète. Un hôte connecté derrière SWPIRATE peut joindre un poste du VLAN 20 alors que ce VLAN ne devrait être accessible qu'aux administrateurs. Toute donnée échangée en clair entre PC_EVIL et PC_ADMIN — y compris des identifiants de session, des accès SSH ou des sauvegardes — devient interceptable. C'est exactement le scénario de VLAN hopping que les contre-mesures de la phase suivante visent à neutraliser.

7 • Scellement final & retour à l'état sûr

« La porte interdite est refermée par trois sceaux : le port redevient access, la négociation est refusée, et DAI détruit les ARP sans preuve de légitimité. »

— Yugi Muto

Le scellement combine trois mécanismes de défense complémentaires. Le retour du port en mode `access` annule la possibilité même de transport multi-VLAN. La directive `switchport nonegotiate` empêche toute négociation DTP future, qu'elle soit initiée par l'attaquant ou par un équipement légitime mal configuré. Dynamic ARP Inspection, déjà active au niveau du cœur de réseau, filtre toute trame ARP émise par PC_EVIL qui ne possède pas d'entrée légitime dans la binding table DHCP Snooping.

Configuration finale — SWA1 e0/2

```
interface Ethernet0/2
  description PORT_SECURISE_CONTRE_TRUNK_ABUSIF
  switchport mode access
  switchport access vlan 10
  switchport nonegotiate
  spanning-tree portfast edge
  spanning-tree bpduguard enable
```

◆ MURMURE DU PUZZLE

Particularité IOU-L2 : les lignes `switchport trunk allowed vlan`, `encapsulation dot1q` et `native vlan` peuvent rester visibles dans la running-config même lorsque le mode actif est `access`. La preuve opérationnelle du scellement n'est donc pas la configuration elle-même, mais le résultat du `show interfaces trunk`, où le port ne doit plus apparaître.

Capture 7.1 — Trunks après scellement

```
SWA1#show running-config interface ethernet0/2
Building configuration...

Current configuration : 323 bytes
!
interface Ethernet0/2
  description PORT_SECURISE_CONTRE_TRUNK_ABUSIF
  switchport access vlan 10
  switchport trunk allowed vlan 10,20,99
  switchport trunk encapsulation dot1q
  switchport trunk native vlan 99
  switchport mode access
  switchport nonegotiate
  spanning-tree portfast edge
  spanning-tree bpduguard enable
end

SWA1#show interfaces trunk

Port      Mode      Encapsulation  Status      Native vlan
---      -
Et0/1     on        802.1q         trunking    99

Port      Vlans allowed on trunk
---      -
Et0/1     10,20,99

Port      Vlans allowed and active in management domain
---      -
Et0/1     10,20,99

Port      Vlans in spanning tree forwarding state and not pruned
---      -
Et0/1     10,20,99
SWA1#
```

`show interfaces trunk` — e0/2 a disparu. Seul e0/1, le trunk légitime, demeure listé.

Capture 7.2 — DAI bloque ARP de PC_EVIL

```
SWA1#
SWA1#show logging | include SW_DAI[DHCP_SNOOPING_DENY]Invalid ARPs
May 16 18:44:00.351: %SW_DAI-4-DHCP_SNOOPING_DENY: 1 Invalid ARPs (Req) on Et0/2, vlan 20.([0050.7966.6804/192.168.20.66/ffff
ffff.ffff/192.168.20.10/18:44:59 UTC Sat May 16 2026])
May 16 18:44:01.351: %SW_DAI-4-DHCP_SNOOPING_DENY: 1 Invalid ARPs (Req) on Et0/2, vlan 20.([0050.7966.6804/192.168.20.66/ffff
ffff.ffff/192.168.20.10/18:44:00 UTC Sat May 16 2026])
May 16 18:44:02.359: %SW_DAI-4-DHCP_SNOOPING_DENY: 1 Invalid ARPs (Req) on Et0/2, vlan 20.([0050.7966.6804/192.168.20.66/ffff
ffff.ffff/192.168.20.10/18:44:01 UTC Sat May 16 2026])
SWA1#
```

Les journaux `SW_DAI-4-DHCP_SNOOPING_DENY` confirment que les trames ARP de PC_EVIL sont systématiquement rejetées.



Avant scellement

PC_EVIL peut joindre PC_ADMIN. Le port e0/2 est trunk, DAI est relâchée, et tout le trafic du VLAN 20 transite par SWPIRATE. Un attaquant placé derrière ce commutateur a une vision directe sur le VLAN sensible.

Après scellement

PC_EVIL est isolé : e0/2 est redevenu access en VLAN 10, `nonegotiate` empêche toute renégociation DTP, et DAI rejette les trames ARP que l'attaquant pourrait forger. Le Royaume des Ombres ne franchit plus les murs du réseau.

8 · Synthèse défensive

Le tableau ci-dessous synthétise les correspondances attaque ↔ défense que tout étudiant doit savoir restituer à l'oral, sans support, en salle 409. Chaque ligne associe une famille d'attaque connue, son effet recherché sur le LAN, la défense Cisco correspondante et la commande de vérification qui apporte la preuve formelle de son efficacité.

Famille d'attaque	Effet recherché	Défense Cisco	Commande de preuve
STP Root Spoofing	Détourner l'élection du Root Bridge, s'insérer au centre L2.	PortFast + BPDU Guard sur ports utilisateurs.	<code>show interfaces status err-disabled</code> , logs.
VLAN Hopping (trunk abusif)	Transporter un VLAN non autorisé vers un poste attaquant.	Access mode + <code>nonegotiate</code> + VLAN natif 99 inutilisé.	<code>show interfaces trunk</code> , ping inter-VLAN avant/après.
ARP Poisoning	Forger une association IP/MAC pour intercepter le trafic.	Dynamic ARP Inspection (DAI), prérequis DHCP Snooping.	<code>show ip arp inspection</code> , logs <code>SW_DAI-4-...</code> .
DHCP Spoofing	Distribuer une fausse passerelle ou un faux DNS.	DHCP Snooping sur les VLANs concernés, port serveur trusted.	<code>show ip dhcp snooping</code> , binding table.
MAC Flooding	Saturer la table CAM pour faire diffuser tout le trafic.	Port-Security en mode sticky, maximum 1 MAC par port.	<code>show port-security interface</code> .

Principe directeur. La sécurité d'un LAN ne se résume jamais à une seule commande magique. Elle résulte de la combinaison de quatre niveaux complémentaires : rôle strict des ports (access vs trunk), délimitation explicite des VLANs autorisés sur chaque trunk, contrôle des relations de confiance DHCP et ARP, et verrouillage STP sur les ports terminaux. Toute simplification de l'une de ces couches affaiblit l'ensemble.

9 • Conclusion

Ce TP a démontré que la couche d'accès — souvent perçue comme la moins critique d'une infrastructure réseau — concentre en réalité une part importante de la surface d'attaque exploitable par un adversaire interne. Deux scénarios offensifs ont été reproduits sur une topologie GNS3 réaliste : une tentative d'usurpation du Root Bridge STP par insertion d'un commutateur pirate, et une exploitation de port d'accès en mode trunk permettant d'atteindre un VLAN administratif théoriquement isolé. Dans les deux cas, la défense Cisco standard (PortFast + BPDU Guard, mode access strict + `nonegotiate`, DAI couplée à DHCP Snooping) a neutralisé l'attaque de façon vérifiable, traçable et reproductible.

Au-delà de la simple configuration des commandes, ce travail a mis en évidence l'importance de la *preuve* en sécurité opérationnelle. Une protection qui ne peut pas être démontrée par capture CLI ou par test fonctionnel reste, du point de vue de l'auditeur, une simple hypothèse. C'est cette discipline — formuler une menace, configurer une défense, et apporter la preuve de son efficacité — qui constitue la véritable compétence attendue à l'issue du module R4.Cyber.09.

Sur le plan méthodologique, la limite assumée sur la négociation DTP rappelle qu'un rapport honnête vaut mieux qu'un rapport spectaculaire : reproduire manuellement un état réseau dont l'origine exacte n'a pas pu être prouvée permet de tester rigoureusement les contre-mesures, sans en exagérer le contexte d'apparition. Cette posture rejoint le travail réel des équipes *blue team* en entreprise, qui privilégient toujours la robustesse vérifiable à la spectacularité de la démonstration.

Les configurations complètes, le manuel d'utilisation de la topologie et les commandes de vérification sont fournis en annexe. Le projet GNS3 exporté est disponible via le portail de rendu universitaire.

10 • Annexes

A.1 • Outils requis & installation

L'ensemble des manipulations a été réalisé sous Windows 10/11 avec les outils suivants. La topologie est portable : l'export GNS3 fourni peut être importé sur tout poste disposant de la même version de la GNS3 VM.

Outil	Version	Rôle dans le TP	Source d'installation
VMware Workstation Pro / Player	17.x	Hyperviseur hébergeant la GNS3 VM	Site officiel Broadcom / VMware
GNS3 Desktop	2.2.59	Interface graphique, orchestration du projet	gns3.com — installateur Windows
GNS3 VM	2.2.59	Exécution des IOU-L2 et VPCS côté serveur	OVA fourni avec GNS3 Desktop
Image IOU-L2	i86bi-linux-l2-adventerprisek9-15.2d.bin	Commutateurs SWA1, SWA2, SWCORE, SWPIRATE	Lien Drive fourni (image + licence)
VPCS	Inclus GNS3	Postes PC_YUGI, PC_MARIK, PC_EVIL, PC_ADMIN	Inclus dans GNS3
Wireshark	Récemment (optionnel)	Observation paquet à la demande du correcteur	wireshark.org

Procédure d'installation rapide

1. Installer VMware Workstation (Player ou Pro).
2. Installer GNS3 Desktop avec ses dépendances Windows.
3. Importer la GNS3 VM dans VMware Workstation à partir de l'OVA fourni.
4. Démarrer la GNS3 VM et vérifier qu'elle obtient une IP, et que le port 80 / 3080 est joignable depuis le poste hôte.
5. Dans GNS3 Desktop, ouvrir *Edit* → *Preferences* → *Server* puis configurer la GNS3 VM comme serveur principal.
6. Si l'image IOU-L2 n'est pas déjà présente dans la VM, l'importer via SCP ou par l'interface GNS3.
7. Ouvrir le projet GNS3 exporté joint au rendu, puis démarrer tous les équipements.

A.2 · Manuel d'utilisation de la topologie

Une fois le projet GNS3 ouvert et tous les équipements démarrés, les manipulations suivantes permettent de rejouer intégralement le TP.

Rejouer l'attaque STP (Chapitre 5)

1. Vérifier que SWA1 e0/2 est en mode access VLAN 10 avec PortFast et BPDU Guard activés : `show running-config interface ethernet0/2`.
2. Brancher SWPIRATE sur le port SWA1 e0/2 dans la topologie GNS3.
3. Sur la console SWPIRATE, exécuter : `spanning-tree vlan 10 priority 0`.
4. Sur la console SWA1, observer le passage en err-disabled : `show interfaces status err-disabled`.
5. Vérifier le déclenchement de BPDU Guard dans les journaux : `show logging | include BPDU|ERR|err`.

Rejouer l'attaque VLAN 20 (Chapitre 6)

1. Basculer manuellement SWA1 e0/2 en mode trunk autorisant les VLANs 10, 20 et 99.
2. Vérifier l'apparition du trunk : `show interfaces trunk`.
3. Depuis PC_EVIL configuré en 192.168.20.66/24, tester : `ping 192.168.20.10`.
4. Restaurer la configuration finale du port (access VLAN 10, `nonegotiate`, PortFast, BPDU Guard).
5. Vérifier le retrait du trunk : `show interfaces trunk` — e0/2 ne doit plus apparaître.
6. Re-tester le ping : il doit échouer, signe que le scellement est complet et que DAI bloque les ARP non valides.

État final sécurisé — Checklist

- SWA1 e0/2 est en mode access VLAN 10 et n'apparaît plus dans `show interfaces trunk`.
- DAI est actif sur les VLANs 10 et 20 : `show ip arp inspection`.
- Les trunks légitimes (SWA1-SWCORE et SWCORE-SWA2) sont déclarés trusted pour DAI et DHCP Snooping.
- Les configurations ont été sauvegardées avec `copy running-config startup-config` sur chaque commutateur.

A.3 · Configurations complètes des équipements

SWA1 — interfaces clés

```
interface Ethernet0/0          ! PC_YUGI
  switchport access vlan 10
  switchport mode access
  switchport port-security mac-address sticky
  switchport port-security
  spanning-tree portfast edge
  spanning-tree bpduguard enable
  ip dhcp snooping limit rate 10
  !
interface Ethernet0/1          ! TRUNK_TO_SWCORE
  switchport trunk allowed vlan 10,20,99
  switchport trunk encapsulation dot1q
  switchport trunk native vlan 99
  switchport mode trunk
  ip arp inspection trust
  ip dhcp snooping trust
  !
interface Ethernet0/2          ! PORT SÉCURISÉ
  switchport access vlan 10
  switchport mode access
  switchport nonegotiate
  spanning-tree portfast edge
  spanning-tree bpduguard enable
```

SWCORE — trunks légitimes

```
interface Ethernet0/0          ! TRUNK_TO_SWA1
  switchport trunk allowed vlan 10,20,99
  switchport trunk encapsulation dot1q
  switchport trunk native vlan 99
  switchport mode trunk
  ip arp inspection trust
  ip dhcp snooping trust
  !
interface Ethernet0/1          ! TRUNK_TO_SWA2
  switchport trunk allowed vlan 10,20,99
  switchport trunk encapsulation dot1q
  switchport trunk native vlan 99
  switchport mode trunk
  ip arp inspection trust
  ip dhcp snooping trust
```

SWA2 — PC_MARIK & PC_ADMIN

```
interface Ethernet0/0          ! PC_MARIK
  switchport access vlan 10
  switchport mode access
  switchport port-security mac-address sticky
  switchport port-security
  spanning-tree portfast edge
  spanning-tree bpduguard enable
!
interface Ethernet0/1          ! TRUNK_TO_SWCORE
  switchport trunk allowed vlan 10,20,99
  switchport trunk encapsulation dot1q
  switchport trunk native vlan 99
  switchport mode trunk
  ip arp inspection trust
!
interface Ethernet0/2          ! PC_ADMIN VLAN 20
  switchport access vlan 20
  switchport mode access
  spanning-tree portfast edge
  spanning-tree bpduguard enable
```

A.4 · Commandes de vérification (oral salle 409)

Ces commandes permettent à un correcteur ou à un étudiant interrogé à l'oral de vérifier instantanément l'état de chaque protection sans avoir à parcourir l'intégralité de la running-config.

```
show vlan brief
show interfaces trunk
show spanning-tree vlan 10
show port-security interface ethernet0/0
show ip dhcp snooping
show ip dhcp snooping binding
show ip arp inspection
show ip arp inspection statistics
show interfaces status err-disabled
show logging | include BPDU|SW_DAI|ERR|Invalid
```

— Fin du rapport — Fehmi Amir & Trid Ilias — Rendu du 16 mai 2026 —

Sources graphiques et licence : image utilisée + licence disponibles dans le dossier Drive fourni :

<https://drive.google.com/drive/folders/1tGwzxcMmGhBFL8kQG1-lyA503xZwvBl?usp=sharing>